URBANI

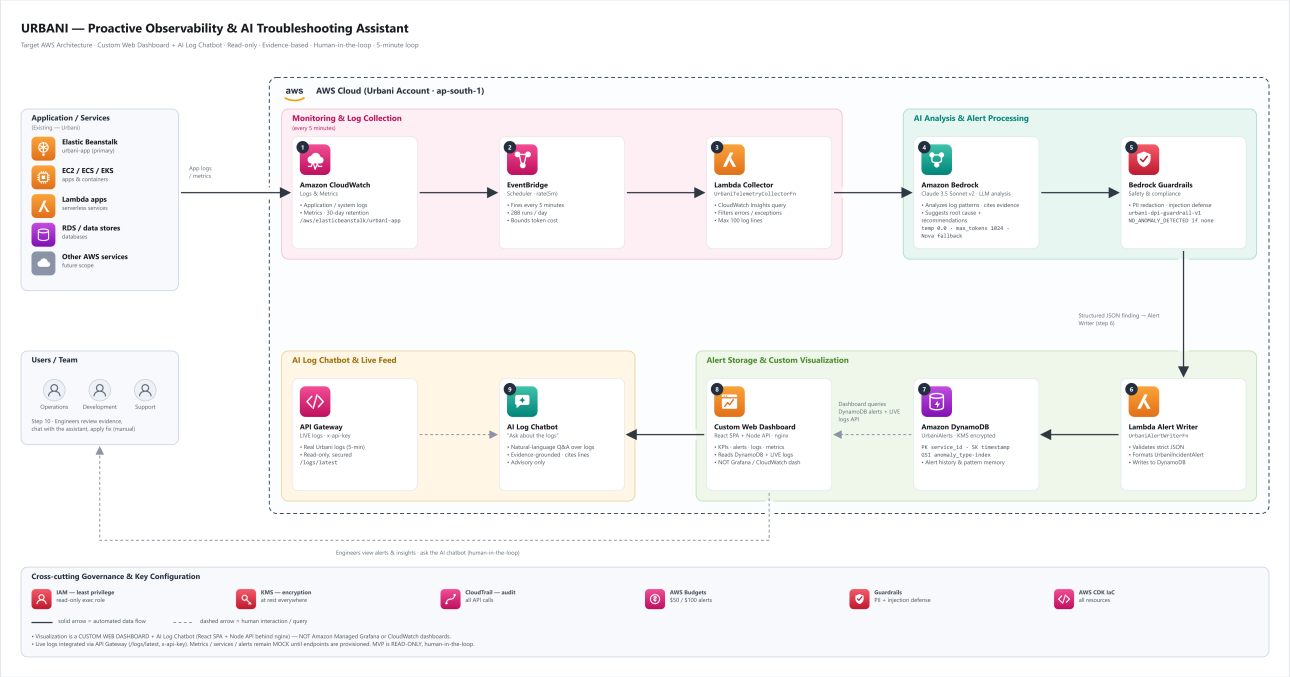
Radar UrbiNexus — DPI 2

Plan, Gap Analysis & Client Requirements

Proactive Observability & AI Troubleshooting Assistant

From MVP to a Secure, Scalable Control Center

This document maps the DPI 2 scope (Radar UrbiNexus) against the delivered DPI 1 system: what was built, what must be upgraded, what is new, and exactly what we need from Urbani to proceed. It covers RBAC and SSO/MFA, DynamoDB persistence, advanced log management and export, email/Slack/Teams alerts, chatbot feedback and history, health KPIs, branding and dark mode. The DPI 1 provenance model (LIVE / MOCK / WAITING_FOR_INTEGRATION) is preserved — no data or answers are fabricated.



DPI 1 architecture baseline. DPI 2 adds Cognito, DynamoDB, SNS/Slack/Teams and Synthetics (see Section 4).

Table of Contents

1. **Executive Summary** 3
2. **What DPI 2 Asks For** 3
   - 2.1 Objectives 3
   - 2.2 Success criteria (the DPI is "successful if…") 3
   - 2.3 Roles to implement (RBAC) 4
3. **What We Delivered in DPI 1 (Baseline)** 4
4. **Gap Analysis — DPI 2 Backlog** 4
5. **Consolidated Upgrade Roadmap** 5
6. **What We Need From Urbani** 6
   - 6.1 Access & identity (hard blockers) 6
   - 6.2 Notification channels (hard blocker for alerts) 6
   - 6.3 Branding & UX (soft — can theme generically first) 6
   - 6.4 Decisions & definitions 6
   - 6.5 Security carried over from DPI 1 (close before go-live) 6
   - 6.6 Logistics / sponsorship 7
7. **Open Questions to Resolve at Kickoff** 7
8. **DPI 2 Kickoff Checklist (one page for the sponsor)** 7

1. Executive Summary

DPI 2 takes the DPI 1 MVP — a working, honest observability dashboard on the Urbani QA environment, a Bedrock Nova 2 Lite incident pipeline, and the read-only AI Copilot — and turns it into a secure, multi-user, multi-service control center ready to scale. The headline changes:

- **Security becomes multi-user:** granular RBAC (4 roles), SSO + MFA (Cognito / Google Workspace), and an audit log. Today: single-level JWT with one bootstrap admin.
- **Persistence moves to DynamoDB:** removes the single-writer limit and enables 2+ ECS tasks across AZs. Today: SQLite, single task.
- **Log management gets serious:** severity/server/date/text/regex filtering, full-stream search (CloudWatch Logs Insights), CSV/JSON/PDF export. Today: only flagged lines, no full-stream search or export.
- **Monitoring expands QA -> Main + Payment:** subject to client access, plus a health/uptime panel and email + Slack/Teams alerts.
- **Chatbot gets evaluation + memory:** like/dislike feedback, conversation history, visible end-to-end latency.
- **UX gets brand identity:** Urbani logo and palette, dark mode, rearrangeable widgets.

The DPI 2 scope estimates ~64 h of effort (about 4 builders over 2 days) across a 13-item backlog (P0/P1/P2). A large share of the work is blocked on client inputs — identity-provider access, Main/Payment log access, notification webhooks, and branding assets (see Section 6).

> **Honest starting point**
> Parts of the DPI 2 "already exists" list describe the target production shape. In the delivered DPI 1 the dashboard runs on ECS Fargate, but the running app persists to SQLite, and the incident/alert pipeline Lambdas are CDK scaffolding (placeholders), not deployed. DPI 2 is where DynamoDB persistence and the notifier pipeline are actually built. We will align this with Urbani so expectations match reality.

2. What DPI 2 Asks For

2.1 Objectives

- **Security & access control:** granular RBAC with SSO/MFA and an audit log.
- **Log management & monitoring:** advanced filters + real-time search (severity, server QA/Main/Payment, date range, keywords/regex), export (CSV/JSON/PDF), and automatic alerts by email, Slack or Teams.
- **AI chatbot:** measure usefulness (feedback), keep conversation history, show response latency.
- **Infrastructure KPIs:** health-check/uptime panel for QA, Main, Payment; validate the UI stays smooth under load.
- **User experience:** Urbani corporate identity (logo + palette), dark mode, personalizable dashboard widgets.
- **Traceability:** verify the full deliverable sequence for 100% roadmap coverage.

2.2 Success criteria (the DPI is "successful if…")

- A user authenticates via SSO/MFA and operates only with their role's permissions; a Reader/Auditor cannot modify configuration (validated with per-role test cases).
- Configuration actions and sensitive queries are recorded in the audit log with user, action and timestamp.
- Logs can be filtered (severity, server, date), searched (text/regex), and exported to CSV, JSON and PDF.

- A critical failure (real or simulated) generates an alert by email and in at least one of Slack/Teams.
- Every chatbot response allows a like/dislike, previous sessions can be consulted, and latency is shown.
- The status panel reflects QA, Main, Payment health; where there is no source access, the surface is MOCK or WAITING_FOR_INTEGRATION, never LIVE.
- The UI stays smooth under a load test with massive log generation (thresholds to be defined with Urbani).
- The DPI 1 provenance model is preserved — no fabricated data or answers.

2.3 Roles to implement (RBAC)

- **Super Admin:** full administration.
- **Infrastructure Administrator:** manage infrastructure-facing configuration.
- **QA Operator:** operate QA monitoring; limited configuration.
- **Reader / Auditor:** read-only; cannot modify configuration (enforced server-side).

3. What We Delivered in DPI 1 (Baseline)

Area	DPI 1 delivered state
Dashboard	React 18 + Vite SPA (nginx) + Node 20/Express API, single ECS Fargate task behind an ALB.
Auth	JWT, bcrypt-hashed passwords, one seeded bootstrap admin. Single access level (no roles).
Persistence	SQLite at /data/urbani.sqlite on a mounted volume. Single-writer -> one task only.
Live logs	QA /logs/latest + /logs/history; upstream returns only flagged lines, so real lines are surfaced from alert evidence and merged into the Logs view.
Live incidents	QA /alerts/latest + /alerts/history; evidence correlated to logs; confidence derived from severity and labelled "(derived)".
AI Copilot	QA POST /chat (Bedrock Nova 2 Lite), grounded server-side. Advisory, read-only. No feedback, history, or latency metric.
Metrics / Services	MOCK (QA exposes no endpoints), labelled honestly.
Provenance	LIVE / MOCK / WAITING_FOR_INTEGRATION across every surface. No fabrication.
Secrets	JWT secret + Urbani API key in AWS Secrets Manager via the deploy script.
Incident pipeline (CDK)	EventBridge -> Collector -> Bedrock -> Alert Writer -> DynamoDB written as CDK with placeholder Lambdas; not deployed.
Scope of services	QA only (main, payments under QA). Main/Payment as separate servers not wired.

4. Gap Analysis — DPI 2 Backlog

Each item below maps a DPI 2 backlog task to our DPI 1 baseline: where we are now, the concrete work, and whether it is blocked on a client input (detailed in Section 6). Effort figures are the scope document’s estimates. P0 = essential, P1 = high, P2 = if capacity allows.

#	Backlog item	Pri	Effort	Status now -> delta
1	Persistence SQLite -> DynamoDB (users/prefs, audit, chat, feedback)	P0	5 h	No real DynamoDB adapter today. Build one behind the repository boundary; removes single-writer; enables 2+ tasks.
2	RBAC: 4 roles across API + UI	P0	6 h	Single access level today. Add role model, server-side authorization, UI gating, per-role test cases.
3	SSO (SAML/OIDC, Google Workspace) + MFA	P1	5 h	None today. Cognito federation + group -> role mapping; alternative: JWT + TOTP. IdP-gated.
4	Audit logs for config + sensitive queries	P0	4 h	Partial, SQLite/MOCK today. Persist user/action/ timestamp to DynamoDB; expose in Audit view.
5	Advanced filters + search (severity, server, dates, text/ regex)	P0	6 h	Window-only filtering today. Add API params + pagination + full-stream search via Logs Insights. Access-gated.
6	Export logs/reports (CSV, JSON, PDF)	P1	4 h	None today. Backend export endpoints; large files staged in S3 if needed.
7	Automatic alerts: email + Slack + Teams	P1	6 h	In-app only today. DynamoDB Streams -> Lambda Notifier -> SNS + webhooks; rules by severity/service; dedup. Webhook-gated.
8	Chatbot feedback (like/dislike) + history	P1	6 h	Stateless today. Persist sessions/messages per user; capture feedback; resume prior sessions.
9	AI latency metric visible in chat	P1	3 h	Not surfaced today. Measure end-to-end latency (incl. Urbani /chat), display per answer. Quick win.
10	Health/uptime panel (QA, Main, Payment)	P1	5 h	No panel today. CloudWatch Synthetics + Route 53 health checks; Container Insights. Access-gated.
11	Corporate branding + dark mode	P1	4 h	Generic theme today. Apply logo + palette; dark-mode toggle persisted per user. Asset-gated.
12	Dashboard personalization (rearrangeable widgets)	P2	4 h	Fixed layout today. Draggable widgets; per-user layout persisted in DynamoDB.
13	Load tests for dashboard + API	P2	4 h	None today. Distributed Load Testing on AWS / k6; extend the automated suite. Threshold-gated.

Estimated total effort: ~64 h. Estimates and owners confirmed at kickoff.

5. Consolidated Upgrade Roadmap

Ordered by dependency and priority. Items marked "gated" cannot reach LIVE without the matching client input in Section 6.

- **1 (P0):** DynamoDB persistence — foundation for roles, audit, chat history, preferences, multi-task.
- **2 (P0):** RBAC — 4 roles, API + UI.
- **3 (P0):** Audit logging.
- **4 (P0):** Advanced log filters + search (Logs Insights / regex) — access-gated.
- **5 (P1):** SSO + MFA (Cognito/Google) or JWT+TOTP fallback — IdP-gated.
- **6 (P1):** Alerts to email + Slack/Teams — webhook-gated.

- **7 (P1):** Chat feedback + history.
- **8 (P1):** AI latency metric — quick win, can start day 1.
- **9 (P1):** Health/uptime panel QA/Main/Payment — access-gated.
- **10 (P1):** Branding + dark mode — asset-gated.
- **11 (P1):** Log/report export CSV/JSON/PDF.
- **12 (P2):** Dashboard widget personalization.
- **13 (P2):** Load tests + extended automated suite — threshold-gated.

New AWS services introduced in DPI 2: Cognito, DynamoDB (as the live store), DynamoDB Streams, Lambda Notifier, SNS, CloudWatch Synthetics, Route 53 health checks, Container Insights, S3 (export), and Distributed Load Testing / k6.

6. What We Need From Urbani

These inputs unblock the backlog. "Hard" means work cannot start; "Soft" means we can start against a MOCK/placeholder and flip to LIVE later.

6.1 Access & identity (hard blockers)

- **AWS account/region + permissions:** to create DynamoDB, Cognito, SNS, Lambda, Synthetics, S3, IAM roles. Unblocks items 1,3,4,7,10,13.
- **Identity Provider admin access:** Google Workspace (or chosen IdP) to configure SAML/OIDC + MFA, plus the group -> role mapping. Unblocks item 3 — or confirm the JWT+TOTP fallback.
- **Read access to Main and Payment:** logs/metrics (plus where those services run and how to probe health) — or an explicit decision to treat them as MOCK. Unblocks items 5,10.
- **CloudWatch log-group names/ARNs:** for QA/Main/Payment + permission to run Logs Insights — or agreement to extend the Urbani /logs API for full-stream search. Unblocks items 5,6.

6.2 Notification channels (hard blocker for alerts)

- **Destination email address(es):** for SNS alert subscriptions.
- **Slack and/or Teams webhook URL:** authorized by Urbani (stored in Secrets Manager).
- **Alert rules:** which severities/services notify, and the deduplication window.

6.3 Branding & UX (soft — can theme generically first)

- **Official Urbani logo:** SVG + PNG for header/nav.
- **Corporate color palette:** exact hex values (primary/secondary/dark-mode).
- **Dark-mode guidance:** if different from a straight inversion.

6.4 Decisions & definitions

- **RBAC permission matrix:** exactly what each of the 4 roles may view and do (especially Reader/Auditor restrictions).
- **SSO vs JWT+TOTP:** pick the authentication approach (affects the IdP dependency).
- **Audit scope:** which actions/queries are "sensitive"; retention for audit, chat history, exports.
- **Load/performance thresholds (SLOs):** explicitly "to be defined with Urbani" (p95 latency, concurrent users, log rate).
- **Data privacy:** confirmation that stored chat/exports are PII-free or de-identified; KMS encryption at rest assumed.

6.5 Security carried over from DPI 1 (close before go-live)

- **Rotate the shared Urbani API key:** and store the new value in Secrets Manager.

- **Replace the bootstrap admin password:** with a strong secret in Secrets Manager (dev default currently in use).

6.6 Logistics / sponsorship

- **Named Urbani sponsor:** the scope doc leaves this to be confirmed.
- **Confirmed builders + dates + rooms:** the doc assumes ~4 builders over 2 days.
- **Repository + IAM + Bedrock access:** GitHub/CodeCommit access, builder IAM, Bedrock model access, AWS Budgets on.

7. Open Questions to Resolve at Kickoff

- **Full-stream log search:** CloudWatch Logs Insights vs. extending the Urbani /logs API. Drives items 5, 6 and the Main/Payment access ask. Recommendation: Logs Insights if we get log-group access.
- **Auth path:** Cognito+Google (full SSO/MFA, IdP-dependent) vs. JWT+TOTP (lighter, no IdP). Recommendation: Cognito if IdP access is granted in time; otherwise JWT+TOTP to still meet the MFA criterion.
- **DynamoDB data model:** single-table vs per-entity for users/prefs/audit/chat/feedback. Decide at kickoff by access pattern.
- **Main/Payment reality:** real reachable services for LIVE, or MOCK for DPI 2? Caps how much of items 5 and 10 can be LIVE.
- **Alerts channel minimum:** the criterion requires email + at least one of Slack/Teams — confirm which messaging platform Urbani provides.
- **Starting-point honesty:** align that DPI 2 is where DynamoDB persistence and the notifier pipeline are actually built.

8. DPI 2 Kickoff Checklist (one page for the sponsor)

- AWS account + region + builder IAM confirmed; Bedrock access + Budgets on.
- Decision: Cognito+Google SSO or JWT+TOTP. If Cognito: Google Workspace admin access + group -> role map provided.
- Decision: Logs Insights access (log-group ARNs for QA/Main/Payment) or Urbani /logs API extension.
- Main/Payment: LIVE access granted, or agreed as MOCK for DPI 2.
- Notification: alert email(s) + Slack/Teams webhook(s) + severity rules + dedup window.
- Branding: logo (SVG/PNG) + palette hex + dark-mode guidance.
- RBAC permission matrix signed off; audit "sensitive action" list + retention defined.
- Load-test thresholds/SLOs agreed.
- Data confirmed PII-free/de-identified; KMS encryption expectations confirmed.
- DPI 1 carry-overs scheduled: rotate API key, replace bootstrap admin password.
- Sponsor named; builders + dates + rooms/collab tools + repo confirmed.

Prepared from the two client documents (DPI2_Urbani_UrbiNexus_EN.docx and Upgrades_UrbiNexus_DPI_EN.pdf) and the delivered DPI 1 codebase. Effort estimates, owners, and the final architecture (Cognito, DynamoDB, SNS/Slack/Teams, Synthetics) are per the DPI 2 scope and will be confirmed with Urbani at kickoff; ingestion from Main and Payment depends on source access.